Sind wir von NIS2 betroffen?

Betrieb: Muster Elektrotechnik e.U. Datum: 23. Oktober 2026

Quellen geprüft: 19. Oktober 2026

Wahrscheinlich ja: eine wichtige Einrichtung.

Grund: Vertrauensdiensteanbieter sind unabhängig von der Größe erfasst; qualifizierte sind wesentlich, andere wichtig (Art. 2 Abs. 2 Buchst. a Ziff. ii, Art. 3 Abs. 1 Buchst. b und Abs. 2); eine mittlere Einrichtung der in Anhang I genannten Art ist wichtig (Art. 2 Abs. 1, Art. 3 Abs. 2). Die Einstufung folgt der Richtlinie; das nationale Recht entscheidet über Fristen, Behörde und Portal.

Was Sie angegeben haben

Land	Deutschland
Größe	50 bis 249 Beschäftigte, oder weniger als 50 Beschäftigte mit Umsatz und Bilanzsumme jeweils über 10 Millionen Euro
Sektor	Verkehr: Luft, Schiene, Schifffahrt, Straßenverkehrsmanagement
Sonderfälle	Wir sind Vertrauensdiensteanbieter (elektronische Signaturen, Siegel, Zertifikate)
Lieferant betroffener Einrichtungen	Nein

Befunde

FAKT Die Richtlinie gilt für öffentliche oder private Einrichtungen der in den Anhängen I oder II genannten Art, die nach Artikel 2 des Anhangs der Empfehlung 2003/361/EG als mittlere Unternehmen gelten oder die Schwellenwerte für mittlere Unternehmen überschreiten und ihre Dienste in der Union erbringen oder ihre Tätigkeiten dort ausüben. Unabhängig von der Größe gilt sie auch für Anbieter öffentlicher elektronischer Kommunikationsnetze oder -dienste, Vertrauensdiensteanbieter, Namenregister der Domäne oberster Stufe und DNS-Diensteanbieter, für Einrichtungen, die nach der Richtlinie (EU) 2022/2557 als kritisch eingestuft wurden, und für Einrichtungen, die ein Mitgliedstaat einstuft, weil sie der einzige Anbieter eines für kritische gesellschaftliche oder wirtschaftliche Tätigkeiten unerlässlichen Dienstes sind oder weil sich eine Störung wesentlich auf die öffentliche Ordnung, Sicherheit oder Gesundheit auswirken könnte.

→ Richtlinie (EU) 2022/2555, Art. 2 Abs. 1 bis 3 · EUR-Lex · Abruf 2026-10-19

■ FAKT Nach der Empfehlung beschäftigt ein mittleres Unternehmen weniger als 250 Personen und hat einen Jahresumsatz von höchstens 50 Millionen Euro und/oder eine Jahresbilanzsumme von höchstens 43 Millionen Euro; ein kleines Unternehmen beschäftigt weniger als 50 Personen und hat einen Umsatz und/oder eine Bilanzsumme von höchstens 10 Millionen Euro. Die Daten von Partnerunternehmen und verbundenen Unternehmen werden denen des Unternehmens hinzugerechnet. Artikel 3 Absatz 4 des Anhangs, zu öffentlichen Stellen mit 25 % oder mehr, gilt für die Richtlinie nicht. Erwägungsgrund 16 erlaubt den Mitgliedstaaten, den Grad der Unabhängigkeit einer Einrichtung von ihren Partnerunternehmen oder verbundenen Unternehmen zu berücksichtigen.

→ Empfehlung 2003/361/EG, Anhang, Art. 2, 3 und 6 · Abruf 2026-10-19; Richtlinie (EU) 2022/2555, Art. 2 Abs. 1 und Erwägungsgrund 16 · Abruf 2026-10-19

◆ AUSLEGUNG In den Begriffen der Richtlinie ist ein Betrieb daher mittel, sobald er 50 oder mehr Beschäftigte hat oder Umsatz und Bilanzsumme beide über 10 Millionen Euro liegen, und groß mit 250 oder mehr Beschäftigten oder Umsatz über 50 Millionen Euro und Bilanzsumme über 43 Millionen Euro. Das deutsche und das österreichische Gesetz schreiben genau diese Schwellen. Ein Betrieb, der zu einer Gruppe gehört, rechnet die Zahlen der Gruppe hinzu; Österreich rechnet sie nicht hinzu, wenn die Einrichtung organisatorisch, technisch und operativ unabhängig ist.

→ BSI-Gesetz, § 28 Abs. 1, 2 und 4 · gesetze-im-internet.de · Abruf 2026-10-19; NISG 2026, § 25 Abs. 2 bis 4 · ris.bka.gv.at · Abruf 2026-10-19

■ FAKT Wesentliche Einrichtungen sind Einrichtungen der in Anhang I genannten Art, die die Schwellenwerte für mittlere Unternehmen überschreiten, qualifizierte Vertrauensdiensteanbieter, Namenregister der Domäne oberster Stufe und DNS-Diensteanbieter unabhängig von der Größe, mittlere Anbieter öffentlicher elektronischer Kommunikationsnetze oder -dienste, Einrichtungen der öffentlichen Verwaltung der Zentralregierung, nach der Richtlinie (EU) 2022/2557 als kritisch eingestufte Einrichtungen und Einrichtungen, die ein Mitgliedstaat als wesentlich einstuft. Alle anderen erfassten Einrichtungen der in Anhang I oder II genannten Art sind wichtige Einrichtungen.

→ Richtlinie (EU) 2022/2555, Art. 3 Abs. 1 und 2 · Abruf 2026-10-19

FAKT Wesentliche und wichtige Einrichtungen ergreifen geeignete und verhältnismäßige technische, operative und organisatorische Maßnahmen auf Grundlage eines gefahrenübergreifenden Ansatzes, die zumindest zehn Bereiche umfassen: Konzepte zur Risikoanalyse und Sicherheit für Informationssysteme; Bewältigung von Sicherheitsvorfällen; Aufrechterhaltung des Betriebs mit Backup-Management, Wiederherstellung nach einem Notfall und Krisenmanagement; Sicherheit der Lieferkette; Sicherheit bei Erwerb, Entwicklung und Wartung einschließlich Management von Schwachstellen; Konzepte zur Bewertung der Wirksamkeit; grundlegende Cyberhygiene und Schulungen; Kryptografie und gegebenenfalls Verschlüsselung; Sicherheit des Personals, Zugriffskontrolle und Management von Anlagen; und die Verwendung von Multi-Faktor- oder kontinuierlicher Authentifizierung, gesicherter Kommunikation und gegebenenfalls gesicherter Notfallkommunikationssysteme. Die Leitungsorgane billigen die Maßnahmen, überwachen ihre Umsetzung, können für Verstöße verantwortlich gemacht werden und müssen an Schulungen teilnehmen.

→ Richtlinie (EU) 2022/2555, Art. 20, Art. 21 Abs. 1 und 2, Art. 23 Abs. 4 · Abruf 2026-10-19

FAKT Ein erheblicher Sicherheitsvorfall wird dem CSIRT oder der zuständigen Behörde mit einer Frühwarnung innerhalb von 24 Stunden nach Kenntnisnahme, einer Meldung innerhalb von 72 Stunden und einem Abschlussbericht spätestens einen Monat nach der Meldung gemeldet; Vertrauensdiensteanbieter melden innerhalb von 24 Stunden. Die Einrichtungen übermitteln mindestens ihren Namen, Anschrift und Kontaktdaten, Sektor und Teilsektor sowie die Mitgliedstaaten, in denen sie Dienste erbringen, und melden Änderungen innerhalb von zwei Wochen; die Frist für die erste Registrierung und das Portal sind nationales Recht.

→ Richtlinie (EU) 2022/2555, Art. 20, Art. 21 Abs. 1 und 2, Art. 23 Abs. 4 · Abruf 2026-10-19; Richtlinie (EU) 2022/2555, Art. 3 Abs. 4 · Abruf 2026-10-19

FAKT Für Verstöße gegen die Maßnahmen oder die Meldepflichten sehen die Mitgliedstaaten Geldbußen mit einem Höchstbetrag von mindestens 10 000 000 Euro oder 2 % des gesamten weltweiten Jahresumsatzes für wesentliche Einrichtungen und von mindestens 7 000 000 Euro oder 1,4 % für wichtige Einrichtungen vor, je nachdem, welcher Betrag höher ist.

→ Richtlinie (EU) 2022/2555, Art. 34 Abs. 4 und 5 · Abruf 2026-10-19

FAKT Deutschland hat die Richtlinie mit dem BSI-Gesetz vom 2. Dezember 2025 (BGBl. 2025 I Nr. 301) umgesetzt, in Kraft seit 6. Dezember 2025. Wesentliche Einrichtungen heißen dort „besonders wichtige Einrichtungen“, wichtige Einrichtungen „wichtige Einrichtungen“ (§ 28); die Größenschwellen sind die der Empfehlung. Die Einrichtungen registrieren sich beim Bundesamt für Sicherheit in der Informationstechnik (BSI) spätestens drei Monate, nachdem sie erstmals als Einrichtung gelten, über das BSI-Portal, das ein ELSTER-Organisationszertifikat voraussetzt (§ 33); für Einrichtungen, die seit 6. Dezember 2025 erfasst sind, endete diese Frist am 6. März 2026, und das BSI schreibt, dass die gesetzliche Registrierungsfrist abgelaufen ist. Änderungen werden binnen zwei Wochen gemeldet. Erhebliche Sicherheitsvorfälle gehen an die gemeinsame Meldestelle von BSI und Bundesamt für Bevölkerungsschutz innerhalb von 24 Stunden, 72 Stunden und einem Monat (§ 32). Das BSI bietet eine unverbindliche Online-Betroffenheitsprüfung an und erklärt, dass es keine verbindliche Mitteilung über die Betroffenheit erteilt. Bis zum 30. September 2026 hatten sich 20 141 Einrichtungen registriert.

→ BSI-Gesetz vom 2. Dezember 2025, §§ 28, 30, 32, 33 · gesetze-im-internet.de · Abruf 2026-10-19; BSI, FAQ, „Registrierungspflicht“, „NIS-2 in Zahlen“, Newsletter vom 1. April 2026, Pressemitteilungen vom 5. Dezember 2025 und 6. Januar 2026 · bsi.bund.de · Abruf 2026-10-19; Bundesregierung, Meldung vom 8. Dezember 2025 · Abruf 2026-10-19

AUSLEGUNG Wenn Ihr Betrieb erfasst ist und sich nicht registriert hat, ist die Dreimonatsfrist verstrichen; jetzt zu registrieren ist besser als abzuwarten, und die datierte Einschätzung, die dazu geführt hat, gehört in Ihre Nachweisakte. Die Betroffenheitsprüfung des BSI ist ein brauchbarer erster Durchgang, ersetzt die eigene Prüfung aber nicht und hat keine Indizwirkung.

Was als Nächstes zu tun ist

- [ ] Bestätigen Sie die Größe mit den Zahlen der ganzen Gruppe (Beschäftigte, Umsatz, Bilanzsumme) und den Sektor gegen Anhang I oder II; bewahren Sie die datierte Berechnung auf.
- [ ] Registrieren Sie sich beim BSI über das BSI-Portal (ELSTER-Organisationszertifikat), falls noch nicht geschehen; die Frist für seit 6. Dezember 2025 erfasste Einrichtungen endete am 6. März 2026.
- [ ] Lassen Sie die Leitung die Maßnahmen schriftlich billigen und an einer Schulung teilnehmen; beides sind Pflichten des Leitungsorgans.
- [ ] Beginnen Sie mit den Maßnahmen, nach denen jeder Fragebogen zuerst fragt: Multi-Faktor-Authentifizierung auf den Konten, die zählen, geprüfte Backups, ein Vorfallsverfahren, das die 24-Stunden-Frühwarnung liefern kann, Sicherheitsklauseln für Lieferanten.
- [ ] Führen Sie eine datierte Nachweisakte: die Selbsteinschätzung, die Registrierungsbestätigung, die Maßnahmen, die Schulungsnachweise.

Das Sicherheitsnachweis-Toolkit macht aus den Maßnahmen des Artikels 21 eine Selbstauskunft, einen Maßnahmenplan und eine Notfallkarte für einen Betrieb

ohne IT-Abteilung: scutoria.com/de/toolkits/sicherheitsnachweis.

Quellen

1. Richtlinie (EU) 2022/2555 vom 14. Dezember 2022 (NIS-2-Richtlinie): Art. 2, 3, 20, 21, 23 Abs. 4, 26, 34 Abs. 4 und 5, Anhänge I und II, Erwägungsgrund 16. eur-lex.europa.eu, CELEX 32022L2555 · Abruf 2026-10-19.
2. Empfehlung 2003/361/EG der Kommission vom 6. Mai 2003 betreffend die Definition der Kleinstunternehmen sowie der kleinen und mittleren Unternehmen, Anhang, Art. 2, 3 und 6. eur-lex.europa.eu · Abruf 2026-10-19.
3. Deutschland: BSI-Gesetz vom 2. Dezember 2025 (BGBl. 2025 I Nr. 301), in Kraft seit 6. Dezember 2025, §§ 28, 30, 32, 33. gesetze-im-internet.de/bsig_2025 · Abruf 2026-10-19.
4. Deutschland: Bundesamt für Sicherheit in der Informationstechnik (BSI), Seiten „NIS-2 regulierte Unternehmen“, FAQ, „Registrierungspflicht“, „NIS-2 in Zahlen“ (Stand 30. September 2026), Newsletter vom 1. April 2026, Pressemitteilungen vom 5. Dezember 2025 und 6. Januar 2026, Betroffenheitsprüfung betroffenheitspruefung-nis-2.bsi.de. bsi.bund.de · Abruf 2026-10-19.
5. Österreich: Netz- und Informationssystemsicherheitsgesetz 2026 (NISG 2026), BGBl. I Nr. 94/2025, §§ 3a, 24, 25, 26, 29, 32, 51; NISV 2026, BGBl. II Nr. 290/2026. ris.bka.gv.at · Abruf 2026-10-19.
6. Österreich: Bundesamt für Cybersicherheit, Seiten „Registrierung“ (Stand 2. Oktober 2026) und „Meldepflicht und Fristen“ (Stand 5. Oktober 2026). bundesamt-cybersicherheit.gv.at · Abruf 2026-10-19. Parlament, 308 d.B., XXVIII. GP. parlament.gv.at · Abruf 2026-10-19.
7. Europäische Kommission, „NIS2 Directive transposition in EU countries“ (Stand 1. Juli 2025), Meldungen vom 7. Mai 2025 und 8. Juli 2026. digital-strategy.ec.europa.eu · Abruf 2026-10-19.

Dieses Memo ist eine Information auf Grundlage der genannten Quellen, erzeugt am 23. Oktober 2026 aus den Antworten oben. Es ist keine Rechtsberatung und entscheidet nichts anstelle Ihres Betriebs. Jede Aussage trägt ihren Marker, jede Quelle ihr Abrufdatum; prüfen Sie die Quellen erneut, bevor Sie sich auf eine Frist verlassen.